

Table of Contents

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

THEIRD-PARTY RISK MANAGEMENT

Y CYBER SUPPLY CHAIN SEGURIDAD

Manual de Gestor Práctica y Analista Junior

TEN Lo que este manual hace: Explica cómo identificar, evaluar, contratar con, supervisar, responder a los proveedores y salir con seguridad. Combina la gobernanza, las pruebas prácticas, la orientación actual NIST, herramientas de código abierto, plantillas reutilizables y preparación de carreras. Silencio Silencio.

Alberto (Al) Leiva

Primera edición • Julio 2026

Prefacio

Las organizaciones dependen de plataformas de nube, software, procesadores de pagos, consultores, proveedores de datos, servicios gestionados, inteligencia artificial y muchos otros forasteros. La organización puede subcontratar el trabajo, pero no subcontrata el impacto empresarial. Un fallo del proveedor puede exponer datos, interrumpir operaciones, debilitar productos o crear obligaciones legales y de clientes.

Este manual enseña un método de ciclo de vida repetible. No es una opinión legal, una garantía o un programa de certificación universal. Los requisitos varían según contrato, ley, regulador, sector, cliente, sistema y país. Utilice profesionales cualificados de derecho, privacidad, adquisiciones, seguridad y auditoría cuando las decisiones las requieran.

Silencio ** Nota de información actual ** El manual refleja el material oficial comprobado el 14 de julio de 2026, incluyendo NIST SP 1326 (final julio 8, 2026), NIST SP 800-18 Rev. 2 (final junio 30, 2026), NIST SP 800-161 Rev. 1 Update 1, NIST SP 1305, y ZXPROTECTED4X 2.0Z ZX Silencio.

Cómo usar este manual

- Gerentes: comiencen con los Capítulos 2-4, 8-13, 19 y 25.
- Analistas junior: estudiar en orden, luego completar Capítulos 26-29 y el laboratorio ficticio.

- Equipos de adquisiciones y jurídicos: atención a la ingesta, debida diligencia, contratos, a bordo, vigilancia, incidentes y salida.
- Equipos técnicos: enfoque en la nube, cadena de suministro de software, IA, herramientas de código abierto, pruebas de evidencia y coordinación de incidentes.
- Utilizar las plantillas como puntos de partida; adaptar criterios y aprobaciones a su organización.

Tabla de contenidos

Esta es una tabla de contenidos de Word nativa. En Microsoft Word, haga clic en él, seleccione la tabla de actualización y seleccione Actualizar la tabla completa. Word reconstruirá las entradas y números de página después de la edición.

[Prefacio \[2\] \(#preface\)](#)

[Cómo utilizar este manual \[2\] \(#how-to-use-this-manual\)](#)

[Tabla de contenidos \[3\] \(#table-of-contents\)](#)

[Guía de cambio \[6\] \(#chapter-guide\)](#)

[1. TPRM and Cyber Supply Chain Foundations \[7\] \(#tprm-and-cyber-supply-chain-foundations\)](#)

[1.1 Qué buena TPRM produce \[7\] \(#what-good-tprm-produces\)](#)

[1.2 Limitaciones importantes \[7\] \(#important-limits\)](#)

[2. The Third-Party Life Cycle \[8\] \(#the-third-party-life-cycle\)](#)

[3. Gobernanza, estrategia y competencia de riesgo \[9\] \(#governance-strategy-and-risk-appetite\)](#)

[3.1 Documentos del programa \[9\] \(#program-documents\)](#)

[4. Inventario, Clasificación y Tiering \[10\] \(#inventory-classification-and-tiering\)](#)

[4.1 Campos de inventario \[10\] \(#inventory-fields\)](#)

[4.2 Factores de Tiering \[10\] \(#tiering-factors\)](#)

[5. Intake and Inherent Risk \[11\] \(#intake-and-inherent-risk\)](#)

[6. Due Diligence and Research \[12\] \(#due-diligence-and-research\)](#)

[6.1 Componentes de evaluación de NIST SP 1326 \[12\] \(#nist-sp-1326-assessment-components\)](#)

[6.2 Fuentes de investigación \[12\] \(#research-sources\)](#)

[7. Evidence Review and Trust \[14\] \(#evidence-review-and-trust\)](#)

[8. Determinación de riesgos y tratamiento \[15\] \(#risk-scoring-and-treatment\)](#)

- 8.1 Un método defensible [15](#a-defensible-method)
- 9. Requisitos de contrato [16](#contract-requirements)
- 10. Secure Onboarding [17](#secure-onboarding)
- 10.1 Pruebas de aceptación [17](#acceptance-evidence)
- 11. Vigilancia continua [18](#continuous-monitoring)
- 11.1 Frecuencia [18](#frequency)
- 12. Conclusiones, Remediación y Excepciones [19](#findings-remediation-and-exceptions)
- 12.1 Disciplina de excepción [19](#exception-discipline)
- 13. Incidentes y notificaciones de proveedores [20](#supplier-incidents-and-notification)
- 13.1 Prepararse antes de un incidente [20](#prepare-before-an-incident)
- 14. Fourth Parties, Concentration, and Systemic Risk [21](#fourth-parties-concentration-and-systemic-risk)
- 14.1 Qué hacer en el mapa [21](#what-to-map)
- 14.2 Concentración de Treat [21](#treat-concentration)
- 15. Cloud and SaaS Vendors [23](#cloud-and-saas-vendors)
- 16. Software and Open-Source Supply Chains [24](#software-and-open-source-supply-chains)
- 16.1 Proveedores y comprobaciones de productos [24](#supplier-and-product-checks)
- 16.2 SBOM limits [24](#sbom-limits)
- 17. Vendedores de Inteligencia Artificial [25](#artificial-intelligence-vendors)
- 18. Privacidad y Protección de Datos [26](#privacy-and-data-protection)
- 19. Resiliencia, continuidad y salida [27](#resilience-continuity-and-exit)
- 19.1 Prueba de salida [27](#exit-test)
- 20. NIST CSF 2.0 Resultados del proveedor [28](#nist-csf-2.0-supplier-outcomes)
- 21. NIST C-SCRM Guidance in Practice [29](#nist-c-scrm-guidance-in-practice)
- 21.1 Pensamiento de tres niveles [29](#three-level-thinking)
- 22. Compliance and Framework Mappings [30](#compliance-and-framework-mappings)
- 23. Testing and Metrics Evidence [31](#evidence-testing-and-metrics)
- 23.1 Método de prueba [31](#test-method)
- 24. Open-Source Tools [33](#open-source-tools)

24.1 Auxiliar de CISO [33](#ciso-assistant)

24.2 Dependencia-Track [33](#dependency-track)

24.3 CycloneDX [34](#cyclonedx)

24.4 Syft [34](#syft)

24.5 Grype [34](#grype)

24.6 Trivy [34](#trivy)

24.7 OpenSSF Scorecard [34](#openssf-scorecard)

24.8 GUAC [35](#guac)

24.9 OSV-Scanner [35](#osv-scanner)

24.10 DefectDojo [35](#defectdojo)

24.11 Wazuh [35](#wazuh)

24.12 Keycloak [35](#keycloak)

24.13 OWASP ZAP [36](#owasp-zap)

24.14 Greenbone Community Edition [36](#greenbone-community-edition)

24.15 Nmap [36](#nmap)

24.16 Agente de política abierta [36](#open-policy-agent)

25. Libro TPRM de Manager [37](#managers-tprm-playbook)

25.1 Ritmo operativo del administrador [37](#manager-operating-rhythm)

26. Guía de la carrera de analista junior [38](#junior-analyst-career-guide)

26.1 Títulos de trabajo comunes [38](#common-job-titles)

26.2 Trabajo junior típico [38](#typical-junior-work)

27. Laboratorio de Ficción y Cartera [40](#fictional-laboratory-and-portfolio)

28. Plan de aprendizaje de 30 días [41](#thirty-day-learning-plan)

29. Preparación de entrevistas [42](#interview-preparation)

29.1 ¿Qué es TPRM? [42](#what-is-tprm)

29.2 TPRM versus C-SCRM? [42](#tprm-versus-c-scrm)

29.3 ¿El riesgo hereditario versus el riesgo residual? [42](#inherent-versus-residual-risk)

29.4 ¿Cómo se fija un proveedor? [42](#how-do-you-tier-a-supplier)

29.5 ¿Cómo reseñas un informe SOC 2? [42](#how-do-you-review-a-soc-2-report)

29.6 Limitación del cuestionario? [42](#questionnaire-limitation)

29.7 ¿Qué es un SBOM? [42](#what-is-an-sbom)

29.8 ¿Cómo cierra un hallazgo? [42](#how-do-you-close-a-finding)

29.9 ¿Y si un proveedor crítico rechaza la evidencia? [42](#what-if-a-critical-supplier-refuses-evidence)

29.10 ¿Qué hace un buen analista junior? [43](#what-makes-a-good-junior-analyst)

29.11 Preguntas para hacer al empleador [43](#questions-to-ask-the-employer)

30. Plantillas, Glosario, Índice y Referencias [44](#templates-glossary-index-and-references)

30.1 Registro de inventario de proveedores [44](#supplier-inventory-record)

30.2 Documentos de trabajo sobre la debida diligencia [44](#due-diligence-workpaper)

30.3 Revisión de la garantía [44](#assurance-review)

30.4 Registro de búsqueda y excepción [44](#finding-and-exception-record)

30.5 Lista de verificación de contratos y salida [45](#contract-and-exit-checklist)

30.6 Glosario [45](#glossary)

30.7 Índice de asunto [45](#subject-index)

30.8 Referencias oficiales [46](#official-references)

Guía del Capítulo

1. TPRM and Cyber Supply Chain Foundations

La gestión del riesgo de terceros controla los riesgos que plantean las organizaciones externas, los productos, las personas y los servicios.

Un tercero puede albergar sistemas, procesar datos, suministrar software, proporcionar personal, ejecutar operaciones críticas o apoyar a los clientes. La gestión del riesgo de cadena de suministro cibernético (C-SCRM) es más amplia: considera cómo la tecnología está diseñada, desarrollada, fabricada, integrada, entregada, operada, mantenida y retirada en muchos niveles.

1.1 Qué buena TPRM produce

Un inventario completo de proveedores.

Evaluación basada en el riesgo antes del compromiso.

Seguridad, privacidad, resiliencia, auditoría y términos de incidentes en acuerdos.

Acceso controlado y manejo de datos durante el servicio.

Supervisión que detecta cambios materiales y riesgos atrasados.

Realizó la coordinación de incidentes y un plan de salida ejecutable.

1.2 Importantes límites

Item Silencio Lo que no prueba Silencio. Silencio Cuestionario Silencio Una afirmación del proveedor no es una prueba independiente. Silencioso informe SOC 2 Cubre sistemas, criterios, periodo, pruebas y limitaciones, no todos los riesgos. TENIDO ISO certificado Se aplica sólo al alcance certificado y los detalles del certificado actual. Nota de seguridad Silencio Las señales externas pueden ser útiles pero pueden ser incompletas, estancadas o mal atribuidas. Silencio Contrato permanente Una promesa no muestra que un control funciona. Silencio – Herramienta resultado Silencio Automatización es compatible con las pruebas; no toma la decisión del negocio. Silencio

Silencio **Principio del contrato:** Proporcione la actividad, no la responsabilidad. El propietario del negocio sigue siendo responsable de entender y gestionar el impacto. Silencio.

2. El Ciclo de Vida de Terceros

Un proceso de ciclo de vida evita que la evaluación se convierta en un cuestionario único.

■img src="media/imagen1.png" style="width:6.15in;height:3.39605in" alt="El mismo registro debe seguir al proveedor de la solicitud de negocio a través de salida segura." /

Figura 1. Ciclo de vida de riesgo de terceros

Stage Silencio Silencio**————— TENCIÓN ANTERIOR ¿Hay una necesidad válida y un propietario responsable? Silencio Solicitud, descripción del servicio, propietario, alternativas ¿Cuánto daño podría causar el fracaso? – Datos, acceso, dependencia, disponibilidad, geografía Silencio ¿Es aceptable el riesgo residual? Ø Investigación, pruebas, pruebas, hallazgos, tratamiento ¿Son las obligaciones ejecutables? – Condiciones de seguridad/privacy/resilience firmadas Silencio a bordo ¿El acceso es limitado y aprobado? Configuración, cuenta, flujo de datos, registros de aceptación ¿Ha cambiado el riesgo o el rendimiento? – Eventos, testimonios, problemas, métricas, reevaluaciones ¿Se eliminan los accesos, datos, activos y dependencias? – Revocación, supresión/retorno, transición, confirmación

3. Gobernanza, estrategia y competencia de riesgo

Governance establece derechos de decisión, límites de riesgo, financiación y escalada.

3.1 Documentos del programa

- Políticas y normas sobre la gestión de los recursos institucionales.
- El apetito de riesgo y las reglas obligatorias de rechazo o escalada.
- Método de clasificación y evaluación de proveedores.

- Biblioteca de cláusulas de contrato y aprobación de la desviación.
- Vigilancia, incidencia, excepción y procedimientos de salida.
- métricas, reportajes, retención de registros, revisión de calidad y mejora del programa.

Silencio **Role** Silencio. tención Consejo/ejecutivo Silencioso Supervisión, dirección de riesgos, recursos, desafío de riesgo material – Propietario de negocios – Necesidad, crítica, rendimiento, propiedad de riesgo residual, disponibilidad de salida Silencioso Compras Silencio Flujo de trabajo, términos comerciales, renovación, registro de proveedores TEN Legal / privacy TEN Contrato, base legal, regulación, transmisión de datos, asesoramiento de notificación TEN Seguridad / TPRM TENIDO Método, diligencia debida, análisis técnico, monitoreo, hallazgos TENIDO TEN IT/engineering TEN Arquitectura, configuración, acceso, integración, pruebas, recuperación Evaluación independiente del diseño y funcionamiento del programa – Proveedor Silencio Información precisa, controles contratados, aviso, corrección, cooperación

Silencio ** Decisión mayor:** Defina quién puede aceptar qué nivel de riesgo residual. Un propietario de riesgos debe tener autoridad, contexto y rendición de cuentas, no sólo una firma conveniente. Silencio Silencio.

4. Inventario, Clasificación y Tiering

Conocer cada proveedor y escala de trabajo para dañar probablemente.

■img src="media/image2.png" estilo="Ancho:6.15in; Altura:4.02397in" alt="Utilizar los factores documentados y permitir la escalada cuando un factor es especialmente grave".

Figura 2. Ejemplo de fichas de proveedores

4.1 Campos de inventario

- Nombre legal, alias, producto/servicio, propietario de negocios, propietario técnico y propietario del contrato.
- Propósito, sistemas, integraciones, cuentas, privilegios, categorías de datos, ubicaciones de datos y vías de transferencia.
- Procesos críticos, necesidades de recuperación, dificultad de sustitución, cuartas partes, concentración y exposición geográfica.
- Tierno, riesgo inherente, riesgo residual, estado de evaluación, conclusiones, excepciones, fechas de contrato, renovación y estado de salida.

4.2 Factores de inclinación

Silencio **Factor** Silencio **Ejemplo estado de alto riesgo** Silencio—————
 TENER Datos TENIENTES Personal sensible, salud, pago, secretos o información regulada
 TENIDO Acceso TENIDO Privilegiado, producción, remota, persistente o amplia API acceso
 ANTE TEN Disponibilidad TENIDO Failure detiene un producto crítico, operación o servicio al
 cliente TEN Silencio Cambio Silencio Proveedor puede actualizar el código, firmware, modelos,

reglas o infraestructura tención dependencia Silencioso Pocos sustitutos, migración difícil, formato propietario, larga recuperación Silencio Reach Silencio Proveedor sirve muchos sistemas críticos, regiones, clientes o subsidiarias TEN – Incorporación de materiales, subprocesador, nube, identidad, modelo o dependencia de software

5. Ingestión y Riesgo Inherente

Intake captura el uso propuesto completo antes de la presión comercial hace difícil la revisión.

1. Describir el propósito del negocio y por qué se necesita un proveedor externo.
 2. Nombrar contactos comerciales, técnicos, de privacidad, seguridad, adquisiciones y contratos responsables.
 3. Datos de mapa recopilados, creados, accedidos, almacenados, transmitidos, entrenados en, devueltos y eliminados.
 4. Describir conexiones, privilegios, usuarios, ubicaciones, cuartas partes y apoyar el acceso.
 5. Determinar la crítica, las expectativas de recuperación, las alternativas y la dificultad de salida.
 6. Identificar leyes, contratos, requisitos de clientes, residencia de datos y obligaciones sectoriales.
 7. Calcule el riesgo inherente antes de considerar los controles del proveedor.
 8. Asignar la ruta de revisión necesaria y detener la compra o conexión no autorizadas.
- Riesgo hereditario versus riesgo residual* El riesgo inherente es la exposición antes de considerar los controles. El riesgo residual es lo que queda después de controles verificados, términos de contrato, opciones de diseño y otro tratamiento. Silencio

6. Due Diligence and Research

La diligencia debida reúne la información pertinente para que la organización pueda tomar una decisión de adquisición informada o de uso continuado.

■img src="media/image3.png" style="width:6.15in;height:3.39605in" alt="Las solicitudes de investigación y evidencia deben seguir el papel y el riesgo real del proveedor."

Gráfico 3 Corriente de trabajo de diligencia debida

6.1 Componentes de evaluación NIST SP 1326

Silencio **Componente** Silencio **Preguntas para investigar** Silencio

————— ¿Quién posee o influye en el proveedor? ¿Qué jurisdicciones o presiones legales importan? Silencio ¿Dónde se originó el producto, código, componentes, hardware y datos? ¿Pueden rastrearse las afirmaciones? ¿Puede el proveedor soportar, responder y recuperarse de la perturbación? — Prácticas cibernéticas

fundamentales ¿Están presentes la gobernanza básica, el acceso, la vulnerabilidad, la tala, el desarrollo, la respuesta y las prácticas de recuperación? ¿Qué organizaciones aguas arriba y aguas abajo afectan materialmente el producto o el servicio?

6.2 Research sources

- Proveedor de organización, técnica, seguridad, privacidad, resiliencia y evidencia de productos.
- La empresa oficial, regulador, certificación, corte, sanciones, violación, vulnerabilidad y fuentes de seguridad de productos eran legales y pertinentes.
- Informes de auditoría o evaluación independientes y pruebas técnicas gestionadas por el cliente.
- Entrevistas de arquitectura y flujo de datos con personas que operan el servicio, no sólo personal de ventas.

TEN Fairness and accuracy: Verificar identidad, fecha, relevancia, jurisdicción y calidad de fuente. Dar al proveedor una oportunidad razonable para corregir errores de hecho materiales. Siga la ley y la política de selección e información personal. Silencio Silencio.

7. Evidencia y confianza

La evidencia es útil sólo cuando coincide con el servicio, el período, el control y el riesgo que se evalúa.

'img src="media/image4.png" style="width:6.15in;height:3.39605in" alt="Las fuentes de evidencia se complementan unos a otros; ningún artefacto único responde cada pregunta." /

Figura 4. Escalera de confianza en la prueba

Silencio **Artifact** Silencio **Revisión de puntos** Silencio

TEN SOC 2 Tipo 2
TENIDO Entity/system scope, criteria, period, opinion, tests, exceptions, CUECs, subservice organizations, subsequent events – Aceptar la página de portada o un informe para otro producto TENIDO Silencio ISO/IEC 27001 certificado Silencio Certified organization and locations, scope, ISO versión, entidad certificado, acreditación, fechas, status Silencio Assuming certification covers every service and control TEN Silencio Penetration-test report tención Tester independence/skill, scope, date, method, exclusions, severidad, remediation, retest tención Política / estándar Silencio Aprobación, propietario, versión, alcance, acción requerida, excepciones dura Tratar la política escrita como prueba de funcionamiento | Respuesta precisa, respuesta precisa, evidencia de apoyo, lagunas no resueltas TEN Arquitectura / flujo de datos TENSÍ Sistemas, límites de confianza, integraciones, ubicaciones, cifrado, administradores, cuartas partes TENIDO Utilizando un viejo diagrama de ventas ANTE TEN BC/DR test TENIDO Escenario, alcance, objetivos de recuperación, resultados observados, fallos, corrección, retest TENA Aceptar un plan sin una prueba ANTE TEN Vulnerability evidence | Asset coverage,

credenciales, date, severidad, remediation, exceptions, rescane | Contando la salida del escaneo como tratamiento de riesgo

8. Alcanzar riesgos y tratamiento

La puntuación de la tinta apoya decisiones consistentes, pero los números no deben ocultar incertidumbre o problemas individuales graves.

8.1 Un método defensible

- Definir la probabilidad y las escalas de impacto en lenguaje simple.
- Puntuación por escenario: amenaza o fracaso, activo/proceso afectado, debilidad y consecuencia.
- Separar el riesgo inherente de la eficacia del control y el riesgo residual.
- Grabar la calidad de las pruebas, la incertidumbre, las suposiciones y la falta de información.
- Permitir la intensificación obligatoria del uso de datos prohibidos, el acceso privilegiado, la dependencia crítica, las restricciones legales o los hallazgos severos no resueltos.
- Exigir la aprobación en el nivel de autoridad correcto y registrar la revisión/expedición.

Silencio Tratamiento Silencio **Ejemplo** Silencio. Evitar la vida Elige otro producto o mantiene la actividad interna tención Decisión y racionalidad – Reducir los datos de confidencialidad, eliminar el acceso de administración, añadir MFA, fijar vulnerabilidades TENER Control, propietario, fecha, prueba TENIDO Silencioso Transferencia/compartido Silencioso Seguros, indemnizaciones, créditos de servicio, asignación contractual TENCIÓN Exacto plazo y riesgo permanente Silencio Aceptar Silencio Autorizado propietario acepta el riesgo residual definido para un período TENIDO Alcance, razón, aprobador, expiración, monitoreo TENIDO – Contingencia Silencioso proveedor, proceso manual, exportación de datos, recuperación probada Silencioso Trigger, recursos, resultado de la prueba

Silencio Advertencia de puntuación: No promedia un problema catastrófico. Reportar escenarios graves, lagunas de evidencia y concentración separadas de la puntuación general. Silencio.

9. Requisitos contractuales

Los contratos convierten los requisitos seleccionados en responsabilidades ejecutables.

Silencio Área de aislamiento Silencio. Programa de seguridad permanente ¿Qué marco, controles, políticas, pruebas, entrenamiento y pruebas de seguridad son necesarias? Silencio Silencio Uso de datos ¿Qué datos se pueden utilizar, dónde, para qué propósito, durante cuánto tiempo y para la formación de modelos? Silencio Silencio ¿Cómo se manejan menos privilegios, MFA, registro, acceso de apoyo y terminación? Silencio Vulnerabilidad permanente ¿Qué reglas de escaneo, revelación, parche, severidad, remediación y aviso se aplican? Silencio ¿Qué evento activa notar, con qué rapidez, a través de qué canal, con qué actualizaciones y cooperación?

Silencio Subprocesadores Silencio ¿Se requiere aprobación o aviso? ¿Desbordan derechos equivalentes? ¿Hay una lista actual disponible? tención auditiva / evidencia Silencio ¿Qué informes, certificaciones, registros, derechos de prueba y prueba de remediación se pueden solicitar? Silencio ¿Qué disponibilidad, recuperación, respaldo, pruebas, comunicación de crisis y derechos de continuidad se aplican? ¿Qué propiedad, alojamiento, ubicación, característica, modelo AI o cambios de control requieren aviso o aprobación? ¿Cómo se maneja el acceso, datos, claves, activos, registros, soporte de transición, retención y eliminación? Silencio ¿Cómo se alinean las limitaciones, la indemnización, el seguro, los recursos y la cooperación regulatoria con el riesgo?

tención **Revisión legal:** El lenguaje y la aplicabilidad de las cláusulas dependen de la ley, jurisdicción, posición de negociación, hechos y todo el acuerdo. Usar un abogado calificado. Silencio.

10. A bordo seguro

El internado convierte las promesas en entornos técnicos y operativos seguros.

- Confirme la aprobación, los términos firmados, la decisión de riesgo residual, los propietarios y las condiciones previas abiertas.
- Verificar arquitectura, flujo de datos, entornos, ubicaciones, subprocesadores y modelo de soporte.
- Crear cuentas nombradas; utilizar SSO/MFA cuando proceda; aplicar menos privilegios, aprobación, expiración y registro.
- Asegure las teclas API, secretos, certificados, agentes, integraciones, vías de red y canales administrativos.
- Configurar retención, eliminación, intercambio, uso de entrenamiento, respaldos, exportación, alertas y opciones de clientes.
- Prueba seguridad, privacidad, disponibilidad, soporte, contactos de incidentes y requisitos de recuperación/exportación.
- Grabar la base de datos de configuración aceptada y añadir al proveedor a los horarios de vigilancia, incidentes, renovación y salida.

10.1 Aceptación de pruebas

- Aprobado a bordo de la lista de verificación y excepciones sin resolver.
- Lista de acceso, funciones, MFA/SSO, ruta privilegiada, vencimiento y resultados de prueba.
- Flujo de datos de producción y registro de arquitectura.
- Exportación de configuración o capturas de pantalla con fecha, evaluador y valores sensibles protegidos.

- Vigilancia, contacto con incidentes, copia de seguridad/exportación y prueba de preparación de salida.

11. Vigilancia continua

Monitoring detecta cambios significativos y verifica que el tratamiento continúa funcionando.

Signal Silencio** Silencio... TEN Nueva vulnerabilidad crítica o explotación ANTE Confirme el producto/versión afectado, exposición, mitigación, parche y retest Ø Incident, outage, or control failure TEN invoke notification and coordination process; reassess risk TEN tención SOC/ISO/pen-test change – Nuevo subprocesador, propietario, ubicación o proveedor de modelos Silencio financiero o operativo Silencioso de revisión, escrow/export, alternativas, y disparador de salida tención Repetida SLA o la búsqueda de fracaso – Escalate corrective action and residual-risk decision TEN tención Renovación o material característica cambio – Reassess antes del compromiso; actualización contrato y arquitectura Silencio No hay evidencia ni contacto absoluto Silencio Escalar según el nivel y el contrato; no marcar silenciosamente completo

11.1 Frecuencia

1. Usar eventos basados en el nivel y el gatillo, no un único calendario anual universal.
2. Los proveedores críticos pueden necesitar señales continuas, revisión periódica de los servicios, garantía anual, ejercicios y reevaluación impulsada por eventos.
3. Los proveedores de más bajo nivel todavía necesitan propiedad, control sobre los contratos/renovaciones, la derivación de incidentes y la revisión basada en cambios.

12. Conclusiones, Remediación y Excepciones

Un hallazgo es una brecha documentada entre criterios y condición observada.

Silencio **Encuentro del elemento** Silencio... tención Criterios Silencio Exactitud, plazo de contrato, política o norma aprobada Silencio Silencio Qué evidencia mostró, incluyendo la población afectada y la fecha – Riesgo Silencio Credible escenario e impacto empresarial Silencio . Por qué se produjo la brecha; evitar las conjeturas no apoyadas TENCIÓN FORMULADA Corrección específica o control compensatorio Silencio Propietario/fecha Fecha límite de responsabilidad y riesgo TENCIÓN PROVISIONAL TENIDO Medida a corto plazo mientras que la corrección completa está pendiente TEN Retest TENIDO Método, evidencia, resultado, revisor y fecha de cierre

12.1 Disciplina de excepción

Definir el alcance, la razón, los activos afectados/datos/procesos, el riesgo y las alternativas.

Exigir la aceptación autorizada y una fecha de vencimiento.

Añade condiciones, compensa los controles, la vigilancia y los desencadenantes para un examen anterior.

Rastrear la renovación por separado de la rehabilitación; una excepción no es el cumplimiento permanente.

Cerrar sólo cuando la evidencia prueba corrección o la relación afectada termina.

13. Incidentes y notificaciones de proveedores

Los incidentes del proveedor requieren hechos compartidos, roles, relojes, canales y decisiones de recuperación.

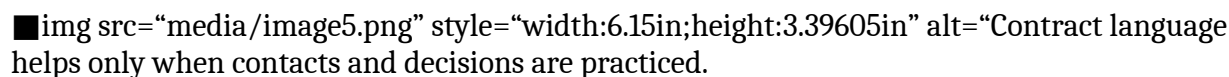
■  Contract language helps only when contacts and decisions are practiced.

Gráfico 5 Coordinación de incidentes de proveedores

13.1 Prepare before an incident

1. Definir eventos reportables y tiempo de notificación, método, receptores, hechos requeridos, frecuencia de actualización y escalada.
2. Mapa acceso a los proveedores, datos, integraciones, activos, cuartas partes y dependencias empresariales.
3. Preaprobar canales de comunicación seguros y contactos alternativos.
4. Clarify evidence preservation, forensic access, regulator/customer support, public statements, containment, recovery, and cost responsibilities.
5. Ejerce escenarios realistas de eliminación de proveedores, incumplimiento, compromiso de software, compromiso de identidad y eliminación de datos.

Silencio **Primeras preguntas** Silencioso...

----- La vida
----- ¿Qué pasó y cuándo? Silencio Establecer plazos y obligaciones de notificación ¿Qué producto, inquilino, región, versión, cuentas, datos y subprocesadores? Silencio ¿Está contenido el evento? ¿Qué sigue activo? confidencialidad Guía de las decisiones de protección ¿Qué evidencia apoya la conclusión actual? Silencio Acto separado de la suposición ¿Qué acciones de los clientes son necesarias? Silencio Coordinar teclas, acceso, parches, configuraciones y comunicación ¿Cuándo es la siguiente actualización? Mantener un ritmo de funcionamiento fiable

14. Cuartas Partes, concentración y riesgo sistémico

El riesgo de la cuarta parte y la concentración puede convertir muchos registros separados de los proveedores en un fallo compartido.

■  Mapa dependencias materiales a través de proveedores, no sólo dentro de cada cuestionario.

Figura 6. Concentración oculta de cuarto partido

14.1 Qué hacer en el mapa

- Regiones nubladas, servicios de identidad, DNS/CDN, carriles de pago, telecomunicaciones, autoridades certificadoras, repositorios de código, registros de paquetes, proveedores de modelos, proveedores de datos y operaciones administradas.
- Propietarios comunes, geografías, instalaciones, tecnologías, componentes de software y canales de soporte.
- Las dependencias de proveedores que no pueden reemplazarse dentro del tiempo necesario de recuperación.
- Visibilidad contractual, controles de flujo, notificación de incidentes, derechos de evidencia y apoyo de salida para las cuartas partes materiales.

14.2 Treat concentration

- Usar arquitectura diversa sólo cuando reduce el fallo correlativo y puede ser operado con seguridad.
- Construir soluciones manuales probadas, exportaciones de datos, rutas alternativas de identidad/recuperación y planes de sustitución.
- Establecer límites de exposición y escalada ejecutiva para una concentración inevitable.
- Realizar trastornos simultáneos en múltiples proveedores.

15. Vendedores de Cloud y SaaS

El riesgo de Cloud y SaaS depende del modelo de responsabilidad compartida y de la configuración de la organización.

Silencio** Silencio. — Seguridad del arrendatario SSO, MFA, roles, cuentas de administración, sesiones, acceso de apoyo, registro de vidas — Datos TENIDO Categorías, tenacidad, encriptación, claves, regiones, réplicas, respaldos, retención, eliminación — Integración Ø APIs, fichas, webhooks, agentes, redes, secretos, alcances, límites de tarifas TENIENDO Aseguramiento TENIDO Servicio en la nube y ubicaciones dentro de informe/certificado alcance TEN Ø Operaciones en la vida Vulnerabilidad, cambio, monitoreo, incidente, capacidad, disponibilidad, recuperación — Funciones del cliente — Configuración, identidades, puntos finales, clasificación de datos, registros, copias de seguridad, respuesta — Exit — Exportar formato, exhaustividad, tiempo, costo, dependencias, eliminación segura, continuidad

TEN Responsabilidad compartida: Un proveedor seguro no crea automáticamente un inquilino seguro. Prueba la configuración, acceso, integraciones, opciones de datos y monitoreo del cliente. Silencio Silencio.

16. Software and Open-Source Supply Chains

El riesgo de robo incluye prácticas de proveedores y cada componente, construye paso, canal de actualización y dependencia.

'img src="media/image7.png" style="width:6.15in;height:3.39605in" alt="Conecte el SBOM y evidencia de seguridad a la versión exacta liberada y operada." /

Gráfico 7 Flujo de evidencia de cadena de suministro de software

16.1 Proveedores y comprobaciones de productos

- Gobernanza de desarrollo segura, modelos de amenazas, revisión de códigos, pruebas, construcción de aislamiento, secretos, acceso, procedencia, firma, aprobación de lanzamiento y control de cambios.
- Canal de divulgación de vulnerabilidades, divulgación coordinada, método de gravedad, objetivos de parche, versiones compatibles, aviso final de vida y asesoramiento al cliente.
- Formato SBOM, versión, integridad, componentes directos/transitivos, licencias, hashes y relación con el artefacto enviado.
- Actualizar la autenticidad, revolver, telemetría, administración remota, configuración predeterminada y fallo seguro.
- Mantenimiento de código abierto, confianza en el contribuyente, transferencia de propiedad, proceso de liberación, determinación de dependencia y plan integrado por abandonos.

16.2 SBOM limits

- Un SBOM es un inventario, no prueba de que el software es seguro.
- Un partido de vulnerabilidad requiere aplicabilidad y análisis de exposición.
- Un SBOM puede omitir tiempo de ejecución, servicio, firmware, construir, o dependencias cargadas dinámicamente.
- Proteger a los SBOM cuando revelan arquitectura sensible; mantenerlos actualizados para cada liberación material.

17. Vendedores de Inteligencia Artificial

Los proveedores de IAI agregan modelos cambiantes, capacitación y datos rápidos, salidas inciertas y cadenas de proveedores ocultas.

“Iniciar el caso de uso permitido, los datos, el impacto, la cadena modelo, la evaluación y el control humano” (Iniciar con el caso de uso permitido, los datos, el impacto, la cadena modelo, la evaluación y el control humano.” /

Figura 8. Corriente de trabajo de riesgo de los proveedores AI

Silencio** Silencio. Silencio Caso de uso / impacto ¿Qué decisión o tarea se apoya? ¿Quién puede ser dañado? ¿Es significativa la revisión humana? tención de datos Silencio ¿Se mantienen, comparten o utilizan los avisos, subidas, salidas, comentarios y registros para la formación? Silencio ¿Qué modelo, alojamiento, plugins, agentes, fuentes de datos y subprocesadores están involucrados? ¿Cómo se maneja el aislamiento, el acceso, los secretos, los permisos de herramientas, la inyección rápida, el abuso y la vigilancia? Silencio TENIDA Privacidad / IP ¿Qué fundamento jurídico, propiedad, licencias, eliminación, ubicación, transferencia y derechos se aplican? TEN ¿Cómo se evalúa la exactitud, el sesgo, la robustez, la explicabilidad, la deriva y la producción insegura para este uso? Silencio ¿Qué cambios de modelo, política, característica, proveedor o entrenamiento desencadenan aviso y reevaluación? Silencio ¿Cómo se manejan los productos dañinos, las fugas, el compromiso modelo, los abusos, las interrupciones y las pruebas? Silencio ¿Pueden exportarse o eliminarse los avisos, archivos, índices, notas finas, registros y datos derivados? Silencio

18. Privacidad y Protección de Datos

El examen de precios sigue los datos a través de toda la cadena de proveedores.

- Identificar personas, categorías de datos, sensibilidad, fuente, propósito, base jurídica y usos prohibidos.
- Minimizar campos, registros, usuarios, ubicaciones, retención y acceso antes de la transferencia.
- Controlador/procesador de mapas o roles equivalentes y cada subprocesador de material.
- Evaluar avisos, consentimiento u otra base legal, derechos individuales, solicitudes gubernamentales y requisitos de transferencia transfronteriza.
- Exigir seguridad, confidencialidad, cooperación contra la violación, auditoría/evidencia, retorno/delección y condiciones de flujo.
- Prueba de acceso, exportación, corrección, eliminación, retención, comportamiento de copia de seguridad y configuración de arrendatario.
- Reevaluar cuando el propósito, los datos, la formación de modelos, la ubicación, el subprocesador, la propiedad o cambios características.
- minimización de datos* Los datos más sensibles son a menudo los datos que un proveedor nunca recibe. Reducir la recogida y el acceso antes de depender de controles complicados. Silencio.

19. Resiliencia, continuidad y salida

Resilience means providing critical outcomes despite provider disruption and leaving safe when necessary.

Capability** Silencioso **Evidence to test** Silencio... – Impacto empresarial TENIDO Servicio crítico, máxima perturbación tolerable, RTO/RPO, dependencias – Respaldo/recuperación | Scope, aislamiento, prueba de restauración, tiempo de observación, pérdida de datos, fallos, retest – Continuidad Silencio Personas, instalaciones, tecnología, comunicaciones, recorridos manuales, ejercicios – Capacidad/disponibilidad viv Arquitectura, regiones, límites, monitoreo, incidentes, desempeño del SLA Silencio Plan de salida Silenciosos, derechos de decisión, alternativa, exportación de datos, eliminación de acceso, secuencia de migración – Deletion | Producción, copia de seguridad, registros, dispositivos, datos derivados, artefactos de AI, subprocesadores, evidencia tención, retención legal, confidencialidad, vulnerabilidad/incidente, apoyo

19.1 Exit test

- Exportar un conjunto de datos representativo y confirmar la integridad, formato, metadatos, permisos y restauración utilizable.
- Inventario de cada cuenta de proveedor, clave, certificado, agente, ruta, dispositivo, licencia, integración y copia de datos.
- Estimar tiempo de migración e interrupción del negocio de pruebas observadas, no reclamaciones de ventas.
- Document who confirms return/deletion and how exceptions such as legal hold or backup retention are controlled.

20. NIST CSF 2.0 Resultados del proveedor

NIST CSF 2.0 coloca la gobernanza de la cadena de suministro en la categoría GV.SC.

Silencio **Responde** Silencio **Plain meaning** Example evidence** Silencio.. Silencio GV.SC-01 TENIDO Un programa C-SCRM, estrategia, objetivos, políticas y procesos son establecidos y acordados por los interesados de la organización. Silencio Programa aprobado y registro de los interesados Silencio GV.SC-02 TENIDO funciones y responsabilidades de ciberseguridad para proveedores, clientes y socios se establecen, comunican y coordinan. Silencio RACI, contactos, acuerdos, ejercicios tención GV.SC-03 Silencio C-SCRM se integra en la gestión del riesgo empresarial, evaluación del riesgo de ciberseguridad y procesos de mejora. – Enlace, registro de riesgos, lecciones y mejoras Los proveedores son conocidos y priorizados por la crítica. tención Completo inventario de proveedores y método de crítica Los requisitos de ciberseguridad de cadena de suministro se establecen, priorizan e incluyen en contratos y acuerdos. biblioteca de requisitos, términos firmados, desviaciones Silencio GV.SC-06 ANTE La planificación y la diligencia debida se realizan antes de iniciar relaciones formales con los proveedores. Silencio Toma, investigación, evidencia, análisis, aprobación Silencio GV.SC-07 Silencio Los riesgos de los proveedores se entienden, registran, priorizan, evalúan, tratan y supervisan a lo largo de la relación. Silencio Registros de riesgos, monitoreo, hallazgos, tratamiento confidencialidad Los proveedores pertinentes están incluidos en la planificación, respuesta y recuperación de incidentes. Ø Planes, contactos, mesas, registros de incidentes Las prácticas de seguridad de cadena de suministro están integradas y supervisadas a lo largo del ciclo de vida útil y de productos tecnológicos. Requisitos para el ciclo de vida, pruebas de productos y servicios Los planes de cadena de suministro de Ciberseguridad incluyen actividades que se producen

después de que termine un acuerdo de asociación o servicio. Silencio Plan de salida, eliminación de acceso/datos, funciones posteriores a la determinación

Usando GV.SC: Define un perfil actual de los resultados observados y un perfil de destino de las necesidades empresariales. Priorizar las lagunas, propietarios, recursos y fechas; no tratar un mapeo como aplicación automática. Silencio Silencio.

21. NIST C-SCRM Orientación en la práctica

Las publicaciones actuales NIST proporcionan orientación complementaria sobre programa, evaluación y planificación.

Silencio **Publicación** Silencio. tención NIST SP 800-161 Rev. 1 Update 1 TEN integra C-SCRM en la gestión de riesgos a nivel institucional, de misión/empresa y de sistema; incluye estrategia, política, planes, evaluaciones y controles. Silencio NIST SP 1305 Silencio Usos NIST CSF 2.0 GV.SC para establecer y operar C-SCRM y comunicar los requisitos de los proveedores. Silencio NIST SP 1326 (final julio 8, 2026) Silencio Consideraciones rápidas para evaluaciones de la diligencia debida del proveedor de TIC: FOCI, procedencia, resiliencia, prácticas cibernéticas fundamentales y cadenas de suministro. Silencio Silencio NIST SP 800-18 Rev. 2 (final junio 30, 2026) Silencio Define elementos esenciales para los planes de seguridad del sistema, privacidad y C-SCRM, incluyendo propósito, estado de control, responsabilidades y comportamiento esperado.

21.1 Pensamiento de tres niveles

Nivel ...

----- - Estrategia de empresa, apetito de riesgo, política común, recursos, supervisión durable Los límites de concentración de proveedores y las métricas del programa TEN Misión / proceso de negocios TENIDO Servicios críticos y dependencias TEN System TENED producto, servicio, arquitectura, controles y plan TENIDO Plataforma cliente utilizando una nube y proveedor de identidad

- Un plan C-SCRM explica los arreglos previstos y aplicados. Los evaluadores todavía necesitan pruebas fiables de que funcionan los controles pertinentes. Silencio.

22. Compliance and Framework Mappings

Los ajustes coordinan el trabajo, pero cada obligación debe ser interpretada y probada en sus propios términos.

Silencioso **Framework / obligation** Silencio **Supplier-risk connection** Silencio

----- Silencio SOC 2 Silencio Gestión de proveedores, riesgos, compromisos, límites del sistema, organizaciones de subservicio, CUECs Silencioso Revisar el alcance exacto del informe, período, criterios, opinión, pruebas, excepciones TEN ISO/IEC 27001:2022 Silencio Partes interesadas, relaciones con los proveedores, cadena de suministro de TIC, uso en la nube, monitoreo y cambio TENIDO El alcance de la certificación y la aplicabilidad del control varían Ø Silencio PCI DSS v4.0.1 Silencio Proveedores de servicios de terceros, responsabilidades, acuerdos, monitoreo, soporte de incidentes TENIDO Validar el propio alcance y responsabilidades de la entidad Silencio HIPAA Silencio Negocios asociados, acuerdos, salvaguardias, incidentes, subcontratistas sometidos Estatus y deberes legales dependen de hechos y leyes TENCIÓN GDPR TENIDO Procesadores, contratos, subprocesadores, seguridad, transferencias, asistencia, supresión/audit ANTERIOR Papeles, jurisdicción, base legal y mecanismo de transferencia requieren análisis legal ANTE TEN CIS Controls v8.1 Ø Control 15 inventario de proveedores de servicios, políticas, clasificación, contratos, evaluación, monitoreo, desmantelamiento de las Salvaguardias son una base de referencia priorizada, no cumplimiento legal universal ANTE Silencio NIST CSF 2.0 TENIDO GV.SC más organización en todo el Govern, Identificar, Proteger, Detectar, Responder, Recuperar los resultados TENIDOS Los perfiles están adaptados; CSF no es una certificación ANTE

23. Pruebas de pruebas y métricas

Testing pregunta si los controles están diseñados, implementados y funcionando correctamente para el alcance completo.

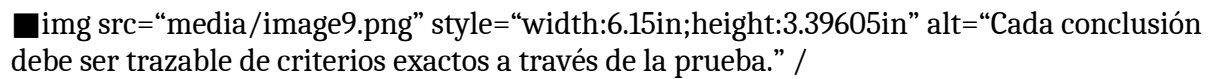
■  Cada conclusión debe ser trazable de criterios exactos a través de la prueba." /

Figure 9. Evidence-testing chain

23.1 Método de prueba

Definir criterios exactos, objetivos, periodos, sistemas, proveedores, datos, ubicaciones y exclusiones.

Identificar la población completa y validar su integridad y exactitud utilizando fuentes independientes cuando sea posible.

Elija pruebas de población completa o una muestra defensible; selección de registros y limitaciones.

Inspeccione, observe, inquire, y reperformance según corresponda. La investigación por sí sola suele ser débil.

Record evidence source, date, owner, version, reviewer, and protected location.

Describir excepciones con precisión y evaluar controles de frecuencia, gravedad, patrón, impacto, causa y compensación.

Realizar una revisión independiente antes del cierre.

Silencio ** Métrico** Silencio **Cálculo del ejemplo** Silencio **Lo que puede revelar** Silencio
 Silencio...----- Silencio Inventario propiedad
 Silencio Proveedores con propietario válido ÷ proveedores activos Silencio Relaciones con los
 huérfanos Silencio tención Evaluación cobertura Silencio proveedores In-scope con evaluación
 completada actual ÷ proveedores in-scope – Cobertura de contrato Silencio proveedores de alto
 nivel con cláusulas requeridas Silencio Critical finding age Silencio Días desde encontrar fecha
 hasta el cierre o hoy Silencio Remediation delay tención – Rendimiento de notificación de
 incidentes Silencio Eventos notificados dentro del tiempo contractual ÷ eventos reportables | Ø
 Proveedores críticos con el plan de exportación / salida probados ÷ proveedores críticos TEN
 Lock-in y la exposición de recuperación – Concentración Silencio Servicios críticos
 dependientes del mismo proveedor/región/tecnología TENCIÓN Fallo relacionado con el
 cuerpo

- Calidad métrica* Siempre mostrar numerador, denominador, fecha, reglas de inclusión, propietario de datos, limitaciones, tendencia y acción. Un porcentaje verde puede ocultar una excepción severa. Silencio.

24. Herramientas de código abierto

Las herramientas de código abierto pueden apoyar inventario, pruebas, seguridad de software, pruebas técnicas, monitoreo y remediación.

Tool** Silencioso**

Silencio. TENIDO CISO Assistant TENIDO Riesgo, controles, evaluaciones, pruebas y hallazgos
 TENENCIA-Track TEN SBOM análisis y monitoreo del riesgo de componentes tención
 CycloneDX Silencioso Software ley de materiales estándar y herramientas tención Syft –
 Generación SBOM para imágenes y sistemas de archivos TEN Grype TEN Vulnerability
 escaneado para imágenes y SBOMs Repositorio, imagen, dependencia, secreto y cheques de IaC
 – OpenSSF Scorecard tención Señales sobre las prácticas de seguridad del proyecto de código
 abierto Silencio GUAC tóxico Graphing software supply-chain metadata TEN OSV-Scanner
 TENIDO Comprobaciones de vulnerabilidad conocida para las dependencias – DefectoDojo
 tóxico Encontrar la ingesta, la deduplicación, la remediación y la retesta TEN Wazuh TENRI
 Endpoint monitoring, file integrity, log analysis, and alerts TEN – Keycloak – Identidad, roles,
 MFA, sesiones y eventos Silencio OWASP ZAP Silencio Autorizado de las pruebas de la
 aplicación web Silencio Greenbone Community Edition Silencio Evaluación de vulnerabilidad
 autorizada Silencio Nmap Silencio Servicio autorizado y descubrimiento de activos TEN Open
 Policy Agent TENIDO Decisiones de política como código

Autorización y límites: Utilice herramientas sólo en sistemas, repositorios, redes, datos y cuentas que posee o tiene permiso escrito para probar. Protege los resultados. Una herramienta apoya la evidencia; no certifica a un proveedor o reemplaza el juicio legal, empresarial y humano. Silencio Silencio.

24.1 CISO Assistant

Propósito: Riesgo, controles, evaluaciones, pruebas y hallazgos. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Crear un proyecto de alcance, definir criterios de riesgo, asignar propietarios, adjuntar pruebas revisadas, registrar hallazgos y restringir el acceso.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.2 Dependency-Track

Objetivo: Análisis de la SBOM y vigilancia del riesgo de componentes. Proyecto oficial: [ejecutado]Dependencia-Track realizado/u título](<https://dependencytrack.org/>)

Inicio rápido seguro: Importar un CycloneDX SBOM de un proyecto de laboratorio, confirmar componentes, revisar vulnerabilidad y alertas políticas, asignar acciones e importar un nuevo SBOM después de la corrección.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.3 CycloneDX

Propósito: Billetera de software de materiales estándar y herramientas. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Usar un generador oficial para el lenguaje del proyecto, crear un SBOM, validarlo, proteger metadatos sensibles y proporcionarlo a herramientas de análisis aprobadas.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.4 Syft

Propósito: generación SBOM para imágenes y sistemas de archivos. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Correr contra una imagen de laboratorio autorizada, exportar CycloneDX JSON, revisar la cobertura del paquete, grabar la versión y el comando, y almacenar el resultado de forma segura.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.5 Grype

Propósito: Escaneo de vulnerabilidad para imágenes y SBOMs. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Escanear la imagen del laboratorio o su SBOM, validar resultados importantes, identificar versiones fijas, remediar y reescanear.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.6 Trivy

Propósito: Repositorio, imagen, dependencia, secreto y cheques IaC. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: escanear sólo repositorios o imágenes aprobados, alcance de revisión y falsos positivos, hallazgos correctos, excepciones de documentos, y rescane en CI.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.7 OpenSSF Scorecard

Propósito: Señales sobre prácticas de seguridad de proyectos de código abierto. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Revisar un proyecto público o un repositorio autorizado, entender cada cheque, verificar las señales importantes manualmente, y no tratar la puntuación como prueba de seguridad.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.8 GUAC

Propósito: Metadatos de cadena de suministro de software de Gráficos. Proyecto oficial: [Seguido](#)

Comienzo rápido seguro: Cargue el SBOM aprobado y metadatos de vulnerabilidad en un laboratorio, relaciones de componentes de consulta, verifique la procedencia y proteja el gráfico, ya que puede revelar la arquitectura.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.9 OSV-Scanner

Propósito: Comprobación de vulnerabilidad conocida para dependencias. Proyecto oficial: [ejecutado]o(<https://google.github.io/osv-scanner/>)

Inicio rápido seguro: Escanear un fichero de bloqueo autorizado, repositorio, imagen o SBOM; validar la aplicabilidad; actualizar o mitigar; y preservar los resultados antes y después.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.10 DefectoDojo

Propósito: Encontrar ingesta, deduplicación, remediación y retest. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Crear un compromiso de prueba, importar resultados seguros, validar la deduplicación, asignar propietarios y fechas debidas, adjuntar prueba y cerrar sólo después de la prueba.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.11 Wazuh

Propósito: Supervisión de puntos finales, integridad de archivos, análisis de registros y alertas. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Inscribir un punto final de laboratorio, producir un evento de prueba inofensivo, confirmar la recogida y alerta, investigar, y retener la cobertura y evidencia de respuesta.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.12 Keycloak

Propósito: Identidad, roles, MFA, sesiones y eventos. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Crear un reino de laboratorio, configurar roles y MFA, probar casos de conexión a Internet y expiración de acceso a proveedores, luego revisar eventos.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.13 OWASP ZAP

Propósito: Pruebas de aplicación web autorizadas. Proyecto oficial: [Seguido]
(<https://www.zaproxy.org/>)

Comenzar rápido seguro: Usar una aplicación de entrenamiento, tráfico proxy, arrastrar pasivamente, utilizar el escaneo activo sólo con aprobación escrita, validar hallazgos, fijar y retest.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.14 Greenbone Community Edition

Objetivo: Evaluación autorizada de la vulnerabilidad. Proyecto oficial: [ejecutado]Greenbone Community Edition (10)(<https://greenbone.github.io/docs/latest/>)

Inicio rápido seguro: Actualizar los alimentos, definir los objetivos de laboratorio aprobados, utilizar credenciales seguras, revisar la cobertura, validar los hallazgos, corregir y cambiar.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.15 Nmap

Propósito: Servicio autorizado y descubrimiento de activos. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Escanear sólo rangos escritos con opciones limitadas, comparar resultados con inventario, investigar servicios desconocidos, y preservar el alcance y la evidencia de comando.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

24.16 Open Policy Agent

Objetivo: Decisiones de política como código. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escribir una pequeña política de laboratorio para un atributo de proveedor aprobado, probar permitir y negar casos, cambios de revisión entre pares, decisiones de registro y mantener la aprobación de la excepción humana.

Pruebas para retener: aprobación y alcance, herramienta/versión, configuración o comando, fecha, población objetivo, resultado bruto, validación analista, limitación, hallazgo, acción y

retest. Acceso limitado porque los resultados pueden exponer arquitectura sensible o debilidades.

25. Libro de reproducción de TPRM de Manager

Los administradores hacen que el programa sea real estableciendo prioridades, resolviendo conflictos, financiando tratamiento y desafiando pruebas.

****Dashboard area** Silencio **Pregunta principal** La vida... la vida... la vida... la vida... la vida... ¿Conocemos a todos los proveedores activos, propietarios, servicios, ruta de datos y dependencia? Silencio Servicio crítico desconocido o propietario huérfano ¿Se han completado las decisiones de alto riesgo antes del compromiso? tención Compra, acceso o transferencia de datos revisión pasada Silencio Evidencia Silencio ¿Cubre el servicio y el período exactos? TENIDA La brecha material, excepción, alcance débil o informe final TENSIONES FORMULADAS ¿Se han firmado requisitos materiales y se han aprobado desviaciones? Silencio Cláusula crítica ausente o inaplicable viv Findings Silencio ¿Quién tiene problemas graves y atrasados? tención El riesgo grave carece de protección provisional o decisión ¿Podemos contactar y coordinar con proveedores críticos ahora? – Contactos, relojes o roles no probados TENCIÓN TERRITOR ANTE ¿Dónde podría un evento interrumpir varios servicios críticos? La concentración inevitable carece de contingencia ¿Podemos recuperar datos y reemplazar el servicio a tiempo? Silencio No hay ruta de exportación, alternativa o eliminación probada

25.1 Gestor de ritmo operativo

Mensual: revisar cambios críticos, hallazgos severos, incidentes, bypasses, trabajo atrasado y concentración.

Trimestralmente: desafiar la cobertura de alto nivel, el progreso del tratamiento, las lagunas contractuales, la vigilancia de la calidad y la preparación para la salida.

Por lo menos anualmente: estrategia de revisión, apetito, titulación, métodos, recursos, dependencias principales, ejercicios, métricas y mejora del programa.

Renovación o cambio material: reevaluar antes del nuevo compromiso, no después de la firma.

Preguntas que importan: ¿Qué puede fallar? ¿Quién está afectado? ¿Qué evidencia apoya la conclusión? ¿Qué sigue siendo incierto? ¿Quién debe actuar cuando? ¿Cómo sabremos que la solución funcionó? Silencio Silencio.

26. Junior Analyst Career Guide

Los analistas de Junior crean valor produciendo inventarios precisos, exámenes de evidencia, hallazgos y seguimiento.

■img src="media/image10.png" estilo="width:6.15in;height:3.39605in" alt="Trabajo cuidadoso y limitaciones honestas construyen una cartera y confianza profesional." /

Gráfico 10 Júnior TPRM analista

26.1 Títulos de trabajo comunes

Third-Party Risk Analyst

Análisis del riesgo de vendedor

Analista de cadena de suministro cibernético

GRC Analista

Análisis de la seguridad

Analista de riesgo de TI o cumplimiento

Análisis de seguridad de proveedores

Analista de cadena de suministro de software

26.2 Típico trabajo junior

Revisar formularios de admisión y reconciliar inventarios de proveedores.

Clasificar a los proveedores utilizando criterios aprobados y escalar hechos de alto riesgo poco claros.

Solicitar, rastrear y organizar pruebas sin alterar los registros de fuentes.

Lea los informes SOC 2, certificados, políticas, diagramas, resúmenes de prueba y evidencia de resiliencia.

Escribir criterios-condiciones-riesgos-acción hallazgos y hacer un seguimiento de la corrección a través de la prueba.

Mantener el requisito del contrato, subprocesador, contacto con incidentes, reevaluación, renovación y registros de salida.

Utilizar herramientas autorizadas en laboratorios o entornos aprobados y explicar limitaciones.

Preparar resúmenes claros de gerente sin reclamar certeza más allá de las pruebas.

Silencioso** Silencio... – Lifecycle – Registro del proveedor de la ingesta a través de la salida – Evidencia Silencio Anotado SOC 2/ISO / lista de verificación de revisión de la prueba mediante hechos sintéticos Silencio Tres evaluaciones basadas en escenarios con incertidumbre Ø Alfabetización técnica TENIDO SBOM y análisis de la vulnerabilidad de un proyecto de capacitación | Escribir Silencioso Encontrar, resumen del administrador, brecha del contrato, y retest memo – Datos TENIDO Dashboard con poblaciones definidas y cálculos – Ética – Autorización escrita, datos sintéticos, redes y limitaciones honestas

27. Laboratorio Ficcional y Portfolio

Construir una cartera segura con una empresa ficticia, proveedores sintéticos y laboratorios técnicos aislados.

La regla del laboratorio:** Nunca escanee ni pruebe objetivos públicos, empleadores, proveedores o cuentas sin autorización escrita. Use datos sintéticos y sistemas de capacitación intencionalmente vulnerables. No publique secretos ni resultados sensibles. — Respuesta

9. Crear una compañía ficticia de 75 personas con datos de clientes, servicios en la nube, personal remoto, una función de pago y un piloto de inteligencia artificial.
10. Crear diez proveedores ficticios y un inventario completo con propietarios, datos, acceso, dependencias, fechas de contrato y niveles.
11. Escribir registros de admisión y riesgos inherentes para un CRM en la nube, proveedor de TI gestionado, servicio de nómina, biblioteca de software y asistente de inteligencia artificial.
12. Crear un certificado SOC 2, ISO, un resumen de las pruebas, políticas, flujo de datos y hechos de prueba de recuperación; alcance de documentos y lagunas.
13. Escribir tres evaluaciones de la debida diligencia utilizando los cinco componentes NIST SP 1326.
14. Elaborar un registro de riesgos, planes de tratamiento, excepción, lista de verificación de contratos, lista de verificación de embarque y calendario de vigilancia.
15. Generar un SBOM para un proyecto de formación autorizado con Syft o CycloneDX; analizarlo con Grype, Trivy, OSV-Scanner o Dependencia-Track.
16. Crear un mapa de concentración de cuarto partido y una matriz de responsabilidad compartida en la nube.
17. Ejecutar una mesa de incumplimiento del proveedor y un ejercicio de salida y salida del proveedor.
18. Publicar documentos sanitarios, un dashboard, y un informe de gestión de una página claramente etiquetado ficticio y educativo.

Silencio **Artifact** Silencio ** Lo que demuestra** Silencio Silencio. TENIDO inventario de proveedores y ordenamiento TENIDO Gestión y priorización de la población tención Due-diligence memo ANTE Investigación, calidad de la evidencia y decisión razonada TEN — Revisión de la Assurance tención Alcance, período, excepciones, CUECs y limitaciones tención registro de riesgos / encontrar la vida Escenario, criterios, acción, propietario y retestigo TENIDO Lista de verificación del contrato permanente Traducción del riesgo en requisitos ejecutables TEN SBOM laboratorio TENIDO Componente de software y alfabetización de vulnerabilidad tención Incident tabletop tención Roles, facts, communication, and improvement — Exit test | Resilience, portability, revocation, and deletion tención Administrador dashboard Silencio Metrices claras, problemas graves, incertidumbre y acción

28. Plan de aprendizaje de 30 días

Un mes centrado puede crear una capacidad útil de nivel de entrada.

Días Silencio** Silencio————— TENIDO 1–3 TENIDO TPRM/C-SCRM términos, ciclo de vida, roles TENIDO Concept map and lifecycle record Silencio 4–6 Silencio Inventario, crítica, inclinación, riesgo inherente TEN-Supplier inventario y tier memo Silencio 7–10 Silencio debida diligencia y NIST SP 1326 Silencio Tres evaluaciones basadas en la investigación TEN 11–13 TENIDO SOC 2, ISO, prueba de plumas, política, diagramas ANTERI Evidencia crítica documentos de trabajo ANTE TEN 14–16 TENIDO Riesgo, hallazgos, tratamiento, excepciones TENIDO registro de riesgos y dos hallazgos TENIDO TEN 17–19 ANTERIENTE Contratos, a bordo, monitoreando TENIDO Cláusulae y listas de verificación a bordo ANTE TEN 20–22 TENIDO Incidentes, resiliencia, salida TENIDO Tabletop y prueba de salida TEN TEN 23–25 TENIDO Cloud, cadena de suministro de software, AI TENIDO Tres evaluaciones enfocadas Silencio 26–27 Silencio Laboratorio de herramientas de código abierto – SBOM, escaneo, corrección, rescane Silencio TEN 28–30 TENIDA Metrics, portafolio, entrevista TENIDO Dashboard, manager memo, cinco historias de STAR

29. Preparación de entrevistas

Las respuestas de interés deben ser cortas, precisas y atadas a ejemplos.

29.1 ¿Qué es la TPRM?

Un proceso de ciclo de vida para identificar, evaluar, contratar, supervisar, responder y salir de los riesgos de organizaciones, productos, personas y servicios externos.

29.2 TPRM versus C-SCRM?

TPRM gestiona ampliamente las relaciones externas. C-SCRM se centra en el riesgo de ciberseguridad en toda la cadena de suministro de tecnología y el ciclo de vida de productos o servicios.

29.3 ¿Un riesgo hereditario versus residual?

El riesgo inherente existe antes de los controles. El riesgo residual permanece después de controles y tratamiento verificados.

29.4 ¿Cómo fijas un proveedor?

Use factores de impacto documentados como datos, privilegios, disponibilidad, autoridad de cambio, sustitutabilidad, alcance, geografía y dependencias de aguas abajo.

29.5 ¿Cómo revisa un informe SOC 2?

Compruebe la entidad y el sistema exactos, criterios, período, opinión, pruebas, excepciones, CUECs, organizaciones de subservicio y eventos subsiguientes; a continuación, mapelo al uso real.

29.6 ¿Límite Cuestionario?

Es una afirmación del proveedor. valido respuestas importantes con pruebas relevantes, actuales, fiables y lagunas récord.

29.7 ¿Qué es un SBOM?

Un inventario estructurado de componentes y relaciones de software. Mejora la visibilidad pero no prueba la aplicabilidad de seguridad o vulnerabilidad.

29.8 ¿Cómo cierras un hallazgo?

Reprueba el control corregido utilizando criterios definidos y pruebas fiables; no cierra sólo porque el proveedor dice que está fijo.

29.9 ¿Y si un proveedor crítico rechaza pruebas?

Grabar la brecha, utilizar pruebas independientes disponibles, considerar opciones de diseño y contrato, evaluar la incertidumbre y el riesgo, y escalar a la toma de decisiones autorizada.

29.10 ¿Qué hace un buen analista junior?

Alcance cuidadoso, registros completos, escepticismo de evidencia, escritura clara, seguimiento respetuoso, manejo seguro y conclusiones honestas.

29.11 Preguntas para hacer al empleador

¿Qué proveedores y riesgos son más importantes para el programa?

¿Cómo se concilian los inventarios con los registros de adquisiciones, finanzas, identidad, red y aplicaciones?

¿Qué pruebas y normas contractuales se utilizan por nivel?

¿Cómo se intensifican las conclusiones, excepciones, incidentes y renovaciones graves?

¿Qué herramientas se aprueban y cómo se revisa el trabajo analista?

¿Cómo sería el éxito en los primeros 90 días?

30. Plantillas, Glosario, Índice y Referencias

- Estructuras reutilizables, términos clave, índice de sujeto y puntos de partida oficiales.*

30.1 Registro de inventario de proveedores

Silencio** Silencio... TENIDO Nombre legal / servicio TENIDO

Los dueños de negocios y técnicos de la vida siguen adelante. “Pripose” y procesos críticos “vivir” TENIENDO Datos / ubicaciones / transferencias TENIDO

“Acceso a las integraciones / privilegios” “Primeras fiestas / concentración” Silencioso Tier /

Seguridad, privacidad, confidencialidad, acceso, registro, vulnerabilidad, desarrollo, uso de datos, capacitación de IA, ubicación, subprocesador, garantía, auditoría, incidente, resiliencia, cambio, seguro/liability, rescisión, transición, retorno, eliminación y revisión de las obligaciones posteriores a la determinación.

Cada desviación material tiene una decisión de riesgo documentada y propietario.

El inventario de salida abarca datos, cuentas, claves, certificados, agentes, rutas, dispositivos, integraciones, subprocesadores, respaldos, registros, artefactos AI, depósitos legales y pruebas de eliminación.

30.6 Glosario

Silencio** Silencio... Silencio Attestation Silencio Una declaración o informe que proporciona seguridad sobre la materia especificada. tención C-SCRM Silencioso Ciberseguridad de la gestión del riesgo de cadena de suministro. riesgo de concentración TENIDO Exposición creada cuando varios servicios críticos dependen del mismo proveedor, lugar, tecnología o recurso. TEN CUEC TENIDO Control complementario de la entidad de usuario: se espera que el cliente realice un control para alcanzar los objetivos del informe. Silencio tención debida diligencia Silencio Investigación investigativa de la información pertinente del proveedor o producto para una decisión informada. Silencio Silencio Primera parte La organización que gestiona su propio riesgo. TEN FOCI TENIDO La propiedad, el control o la influencia extranjeras. TEN Silencio Cuarta Parte Silencio Un proveedor o dependencia utilizado por el tercero de la organización. Silencio tención Riesgo hereditario tención riesgo antes de considerar controles o tratamiento. Silencio – Provenencia Silencio Origen rastreable e historia de un producto, componente, código, datos o proceso. TENIDO Riesgo residual TENIDO El riesgo permanece después del tratamiento. tención de riesgo TENIDO Cantidad y tipo de riesgo que una organización está dispuesta a perseguir o retener. Silencio TEN SBOM TENIDO Proyecto de ley de materiales: un inventario de componentes estructurado. Silencio Subprocesador Silencio Una parte comprometida por un procesador para procesar datos personales. Silencio Silencio Una organización externa, producto, servicio o persona que apoye a la organización. Silencio TENER TPRM TENIDO Gestión del riesgo de terceros a través del ciclo de vida de relación.

30.7 Subject index

Subjeto** Silencio... Silenciosos vendedores de inteligencia artificial Silencio Nube / SaaS Silencioso Concentración TENIDO LOS CONTRATOS TENIDO 9, 30 Silencioso Evidencia en la vida 7, 23 – Exit Silencio 19, 30 Silencio cuartos de las partes Silenciosos incidentes Silencio Inventario / Tiering Silencio 4 Silencioso analista junior TENCIÓN TERRITORIO TENIDO 23, 25 ANTE Silencio NIST CSF GV.SC Silencio 20 Silencio TEN TERRITORIO NIST SP 1326 Silencioso 6, 21 Silencio Herramientas de código abierto Silencio 24 Silencio confidencialidad Silencio 18 TENIDO ANTERIOR DE PRESUPUESTO Silencio SBOM / software Silencio 16, 24 Silencio Silencio SOC 2 / ISO evidencia TENIDO 7 Silencio Silencioso de la vigilancia de los proveedores

30.8 Referencias oficiales

[Seguido]u Guía de inicio rápido para la evaluación de la diligencia debida

Seguridad del sistema, privacidad y planes C-SCRM

[Seguido] [Seguido] [actúa] 1 Actualización 1 — Prácticas C-SCRM realizadas/u contacto]
(<https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final>)

[se]u fielNIST SP 1305 — CSF 2.0 C-SCRM Guía de inicio rápido realizado/u
fiel](https://csrc.nist.gov/pubs/sp/1305/final)

Seguridad Ciberseguridad 2.0

[]](https://csrc.nist.gov/Projects/cyber-supply-chain-risk-management/publications)

[se]u confianzaCISA ICT Supply Chain Resource Library **/u
contacto](https://www.cisa.gov/ict-supply-chain-resource-library)

[]u título](https://www.cisa.gov/resources-tools/groups/ict-supply-chain-risk-management-task-force)

[]](https://www.cisa.gov/resources-tools/resources/vendor-supply-chain-risk-management-scrm-template)

[]](https://www.cisa.gov/ict-scrm-small-and-medium-sized-businesses-resource-hub)

Normativa de verificación de componentes de software de XZO

[]](https://www.bestpractices.dev/)

Silencio **Recuerdo final:** Cambio de marcos, orientaciones, leyes, contratos, proveedores, amenazas, herramientas, productos e interpretaciones oficiales. Confirme la fuente oficial actual y las obligaciones aplicables antes de una decisión o evaluación real. Silencio Silencio.